

Why Runtime Scanning Is Too Late for Your CI/CD Supply Chain Security

CyberIntel Threat Advisory - automated analysis of source reporting: affected systems, actor attribution, and recommended actions.

INTELLIGENCE SNAPSHOT

Issued by	CyberIntel
Date	15 June 2026
Source	thehackernews
Threat Level	HIGH
Affected Systems / Vendors	CI/CD pipelines, build systems, artifact repositories, AI coding assistants, Linux distributions, open source package registries
Threat Actors	-
CVEs	CVE-2024-3094
Reference	https://thehackernews.com/expert-insights/2026/06/why-runtime-scanning-is-too-late-for.html
Classification	For Authorised Recipients

Executive Summary

The article argues that runtime scanning in CI/CD pipelines is fundamentally flawed because detection occurs after malicious code has already executed, citing the xz Utils backdoor (CVE-2024-3094) as a prime example where a compromised maintainer embedded a payload that went undetected for weeks. Modern supply chain attacks use obfuscated, environmentally triggered payloads and typosquatting to bypass signature-based detection, while the exploitation window has compressed to hours. The author advocates shifting security left to govern dependencies at the point of ingestion, noting that detection-only models cannot keep pace with threats and result in excessive remediation costs, regulatory exposure, and personal liability for security leaders.

■ **THREAT LEVEL: HIGH**

FOCUS: THREAT INTELLIGENCE & MITIGATION

Affected Systems & Vendors

CI/CD pipelines



build systems



artifact repositories



AI coding assistants



Linux distributions



open source package registries



Associated CVEs

CVE-2024-3094



Detection Measures & Mitigation

Implement governance at dependency ingestion point



Block malicious packages before they enter the pipeline



Adopt architecture that prevents compromised dependencies from being consumed



Reduce reliance on runtime scanning as primary defense



Automate package health assessment across vulnerability exposure, supply chain integrity, upstream



sustainability, and license risk